# Parking lot USB exercise

| | |
|---|---|
| **Contents** | Write **2-3 sentences** about the types of information found on this device.<br>● *Are there files that can contain PII?*<br>● *Are there sensitive work files?*<br>● *Is it safe to store personal files with work files?*<br>The drive mixes personal files and work files. Some personal documents are things Jorge would not want to be public, and the work files contain personal data of other employees together with details about how the hospital operates. Keeping both kinds of files on the same device is not a safe habit. |
| **Attacker mindset** | Write **2-3 sentences** about how this information could be used against Jorge or the hospital.<br>● *Could the information be used against other employees?*<br>● *Could the information be used against relatives?*<br>● *Could the information provide access to the business?*<br>The timesheets show who Jorge works with and when, so an attacker could write a convincing email that looks like it comes from a coworker or from a relative. Personal details could also be used to guess his passwords or to put pressure on him. The hospital information could even help someone find a way into the business. |
| **Risk analysis** | Write **3 or 4 sentences** describing technical, operational, or managerial controls that could mitigate these types of attacks:<br>● *What types of malicious software could be hidden on these devices? What could have happened if the device were infected and discovered by another employee?*<br>● *What sensitive information could a threat actor find on a device like this?*<br>● *How might that information be used against an individual or an organization?*<br>A drive like this could hide malware, for example a keylogger or ransomware, that runs as soon as it is plugged in. If another employee found it and used it at work, the infection could spread through the hospital network. The best defense is a mix of controls. As a managerial control, staff should be trained to never plug in an unknown drive and to hand it over to IT. As an operational control, antivirus scans should run regularly. As a technical control, AutoPlay can be disabled on company computers, so nothing starts on its own. |